

VULNERABILITY ASSESSMENT REPORT FOR

<https://demo.owasp-juice.shop>

Passive Web Application Security Assessment

Prepared For	Future Interns
Prepared By	Omkar Shinde
CIN ID	FIT/MAY26/CS8310
Assessment Type	Passive Vulnerability Assessment
Target	https://demo.owasp-juice.shop
Email	omshinde6606@gmail.com

DATE - 12/05/2026

TASK - 1

TABLE OF CONTENTS

1. Confidentiality Statement	3
2. Disclaimer	3
3. Assessment Overview	4
4. Assessment Components	5
5. Finding Severity Ratings	5
6. Scope	6
7. Executive Summary	6
8. Observation Summary	7
9. Detailed Findings	08
10. Evidence Collection	16
11. Security Weakness Summary	17
12. Recommendations	17
13. Conclusion	18

Confidentiality Statement

This document contains confidential and proprietary security assessment information prepared for educational and internship evaluation purposes only. Unauthorised distribution or disclosure of this report is prohibited without permission from the author.

Disclaimer

This assessment was conducted strictly within a passive and read-only scope.

The following activities were NOT performed during the assessment:

- **SQL Injection exploitation**
- **Brute force attacks**
- **Authentication bypass attempts**
- **Denial-of-Service attacks**
- **Active vulnerability exploitation**
- **Intrusive penetration testing.**

All the findings documented in this report were identified using publicly observable information and passive security assessment techniques.

Assessment Overview

From 10 May 2026, a passive vulnerability assessment was conducted against the OWASP Juice Shop demo application.

The objective of the assessment was to identify publicly observable security weaknesses using non-intrusive and ethical security analysis methodologies.

The assessment focused on:

- **Publicly exposed services**
- **HTTP security headers**
- **Cookie configurations**
- **Server information disclosure**
- **Browser-based security observations**

The tools used during the assessment include:

Tool	Purpose
Nmap	Service Enumeration
Chrome DevTools	Header & Cookie Analysis
Browser Inspection	Passive Security Review

Assessment Components

Passive Vulnerability Assessment

A passive vulnerability assessment emulates a security auditor's role by analysing publicly observable security weaknesses without performing intrusive exploitation.

The assessment included:

- **Network enumeration**
- **Header inspection**
- **Cookie analysis**
- **Browser-based security review**
- **Infrastructure observation**

No exploitation activities were performed during the assessment.

Finding Severity Ratings

Severity	CVSS V3 Score Range	Definition
Critical	9.0 – 10.0	Severe vulnerability allowing significant compromise
High	7.0 – 8.9	Major weakness with elevated security impact
Medium	4.0 – 6.9	Security weakness requiring remediation
Low	0.1 – 3.9	Minor exposure reduces security posture
Informational	N/A	Additional security observations

Scope

Assessment Details	Value
Assessment Type	Passive Vulnerability Assessment
Target Application	https://demo.owasp-juice.shop
Scope	Read-Only Security Assessment

Executive Summary

During the assessment period, a passive vulnerability assessment was conducted against the OWASP Juice Shop demo application.

The assessment identified several low- and medium-risk security observations related to:

- **Publicly exposed services**
- **Missing HTTP security headers**
- **Cookie handling configurations**
- **Infrastructure disclosure**

The assessment was conducted entirely using ethical and non-intrusive security analysis methodologies.

No exploitation or intrusive penetration testing activities were performed during the assessment.

Observation Summary

Sl. No	Observation	Recommendation	Severity
1	Publicly Exposed Services	Restrict unnecessary public services	Low
2	Missing Content Security Policy Header	Implement CSP Header	Medium
3	Missing X-Frame-Options Header	Implement Frame Protection Headers	Medium
4	Cookie Security Configuration Review	Harden Cookie Security Settings	Low
5	Server Information Disclosure	Reduce Infrastructure Disclosure	Low

Detailed Findings -

1) Publicly Exposed Services

Field	Details
Description	Passive network enumeration identified multiple publicly accessible services exposed by the target application.
Impact	Publicly exposed services increase the visible attack surface and may attract reconnaissance activity.
Severity	Low
System	demo.owasp-juice.shop

Evidence

Detected Services:

- **21/tcp – FTP**
- **80/tcp – HTTP**
- **443/tcp – HTTPS**
- **8080/tcp – HTTP Proxy**


```
(kali㉿kali)-[~]  
$ nmap -Pn -F demo.owasp-juice.shop  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 12:38 -0400  
Nmap scan report for demo.owasp-juice.shop (81.169.145.156)  
Host is up (0.16s latency).  
Other addresses for demo.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::  
rDNS record for 81.169.145.156: w9c.rzone.de  
Not shown: 56 closed tcp ports (reset), 40 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
80/tcp    open  http  
443/tcp   open  https  
8080/tcp   open  http-proxy  
  
Nmap done: 1 IP address (1 host up) scanned in 11.15 seconds
```

Figure 1 – Passive Service Enumeration

Recommendation

- **Restrict unnecessary publicly accessible services**
 - **Apply appropriate network access controls**
 - **Conduct regular service audits**
-

2) Missing Content Security Policy Header

Field	Details
Description	The application response did not include a Content-Security-Policy (CSP) security header.
Impact	Missing CSP protections may increase exposure to browser-based script injection attacks.
Severity	Medium
System	https://demo.owasp-juice.shop

Evidence

Passive browser inspection identified the absence of the Content-Security-Policy response header.

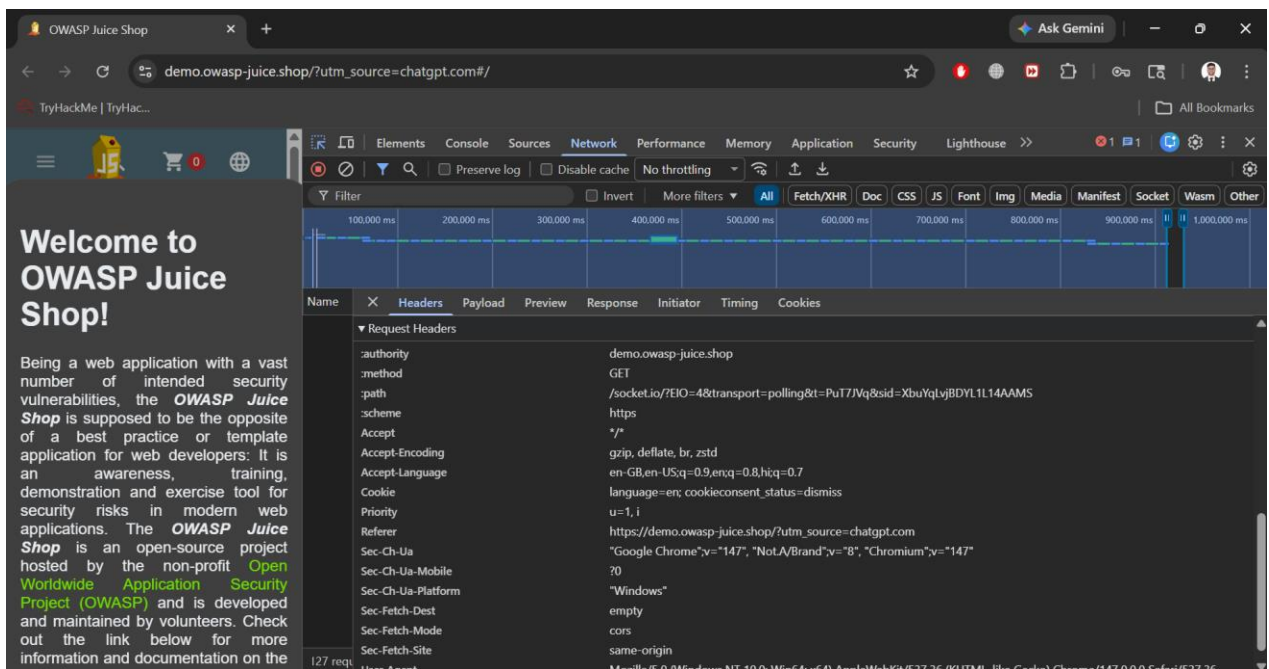


Figure 2 – Security Header Analysis

Recommendation

- **Implement a strict Content-Security-Policy header**
 - **Restrict trusted script and resource origins**
 - **Apply secure browser security policies**
-

3) Missing X-Frame-Options Header

Field	Details
Description	The application response did not include the X-Frame-Options security header.
Impact	Missing frame protection headers may increase exposure to clickjacking attacks.
Severity	Medium
System	https://demo.owasp-juice.shop

Evidence

Passive header analysis identified the absence of the X-Frame-Options security header.

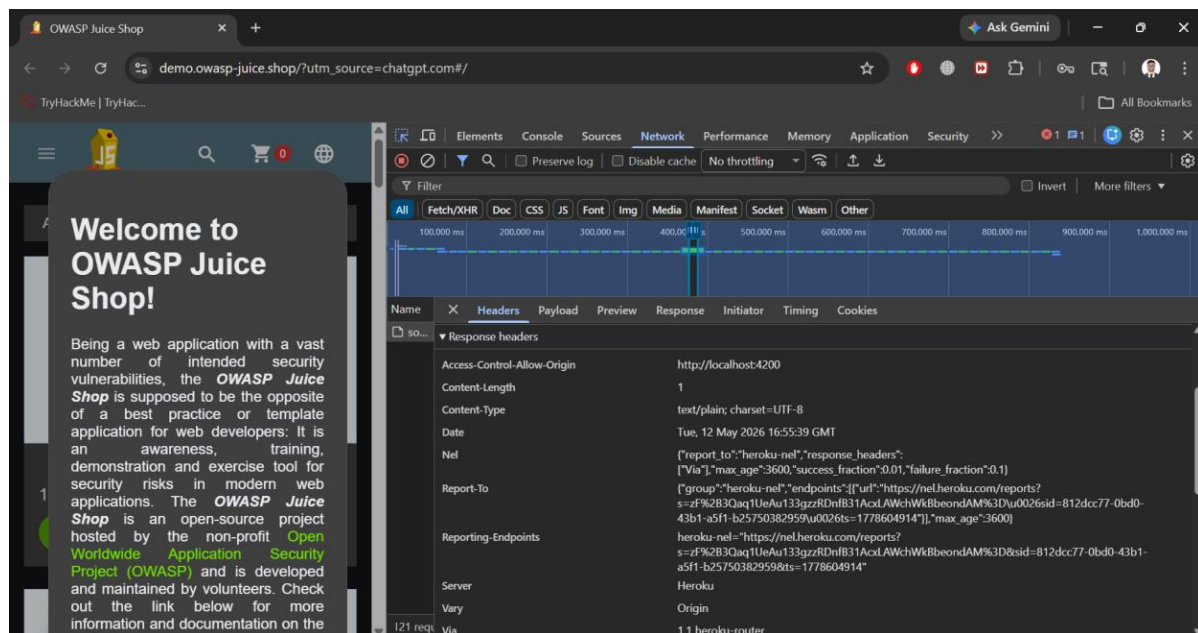


Figure 3 – Response Header Analysis

Recommendation

Implement:

X-Frame-Options:DENY

OR

X-Frame-Options: SAMEORIGIN

4) Cookie Security Configuration Review

Field	Details
Description	Cookie configurations were reviewed during passive browser inspection.
Impact	Weak cookie security configurations may increase client-side security risks.
Severity	Low
System	https://demo.owasp-juice.shop

Evidence

Browser DevTools identified application cookies related to language preferences and consent handling.

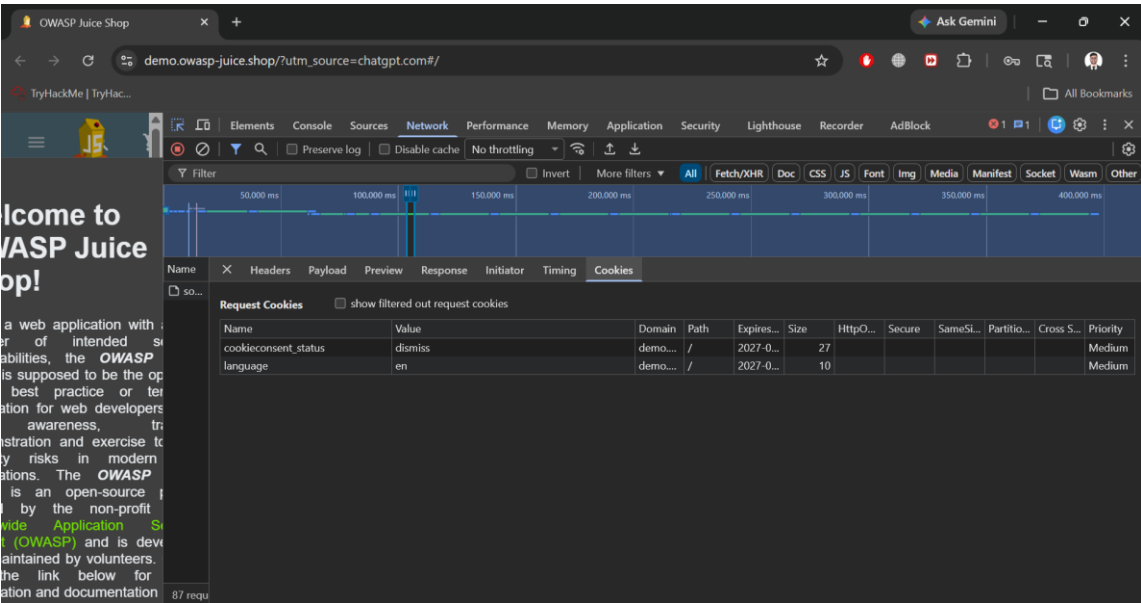


Figure 4 – Cookie Security Configuration Review

Recommendation

- Apply Secure cookie attribute
- Apply HttpOnly protections
- Use Same Site restrictions
- Review sensitive cookie handling

5) Server Information Disclosure

Field	Details
Description	Response headers disclosed backend infrastructure information.
Impact	Infrastructure disclosure may assist attackers during reconnaissance activities.
Severity	Low
System	https://demo.owasp-juice.shop

Evidence

Response headers disclosed backend server information.

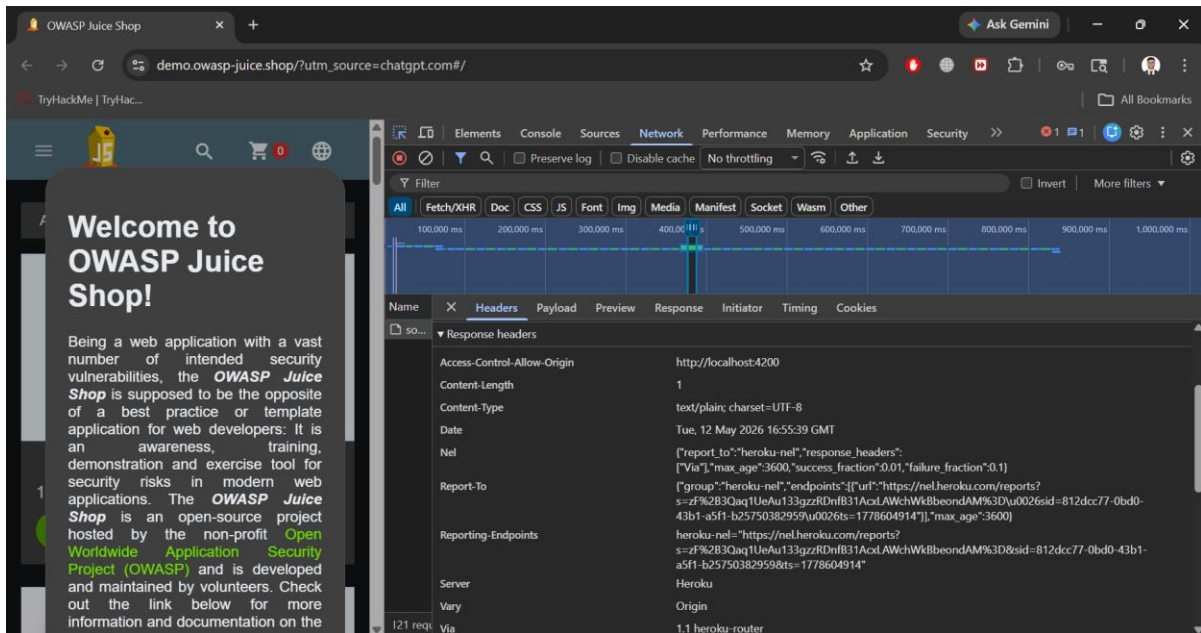


Figure 4 – Cookie Security Configuration Review

Recommendation

- **Reduce unnecessary server banner disclosures**
- **Limit technology stack exposure**
- **Harden HTTP response configurations**

Evidence Collection

Evidence Type	Screenshot
Target Application Homepage	target_application_homepage.png
Nmap Version Verification	nmap_version_check.png
Passive Service Enumeration	nmap_service_enumeration.png
Security Header Analysis	security_header_analysis.png
Response Header Analysis	response_header_analysis.png
Cookie Security Review	cookie_configuration_review.png

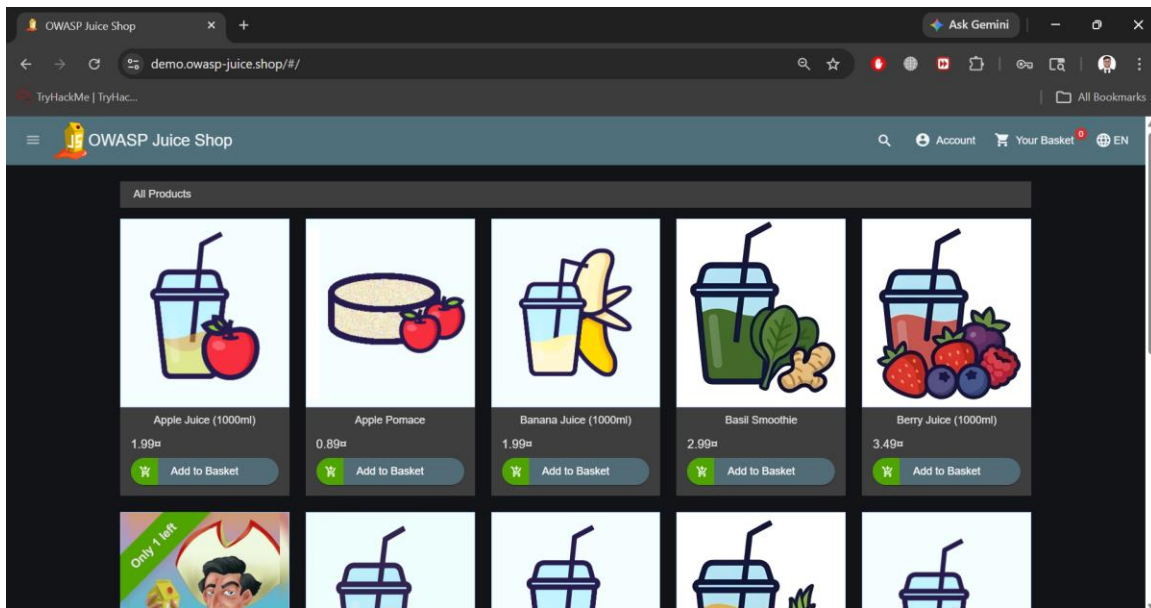


Figure 5 – Target Application Homepage

Security Weakness Summary

Security Weakness	Risk Level	Impact
Public Service Exposure	Low	Increased attack surface
Missing CSP Header	Medium	Browser attack exposure
Missing X-Frame-Options	Medium	Clickjacking exposure
Cookie Configuration Weakness	Low	Reduced client-side protection
Infrastructure Disclosure	Low	Technology stack exposure

Recommendations

The following security recommendations are advised:

- **Implement missing HTTP security headers**
 - **Harden cookie security configurations**
 - **Restrict unnecessary public-facing services**
 - **Reduce infrastructure information disclosure**
 - **Conduct regular passive security assessments**
 - **Apply secure configuration management practices**
-

Conclusion

The passive vulnerability assessment identified several low- and medium-risk security observations related to exposed services, missing HTTP security headers, cookie handling configurations, and infrastructure disclosure.

The assessment was conducted ethically using passive and non-intrusive security analysis methodologies aligned with responsible cybersecurity assessment practices.

While no critical vulnerabilities were identified during the assessment, implementing the recommended security hardening measures would improve the application's overall security posture.